

# EventGenie

## API Reference Documentation

Version 1.0 · Internal Team Reference

## Overview

EventGenie is a multi-tenant event management platform. This document describes all available API endpoints, their request formats, expected responses, and authentication requirements.

### BASE URL

Development: `http://localhost:5000`  
Production: `https://api.eventgenie.com` (to be configured)

### AUTHENTICATION MODEL

All protected endpoints require TWO headers on every request:

| Header          | Value                                                           |
|-----------------|-----------------------------------------------------------------|
| Authorization   | Bearer <firebase_id_token> — Proves Firebase identity           |
| X-Session-Token | <session_jwt> — Proves 2FA was completed (issued by verify-otp) |

*Auth endpoints (register, request-otp, verify-otp, refresh-session) only require the Authorization header.*

### ROLE HIERARCHY

| Role                      | Scope           | Access Level                                |
|---------------------------|-----------------|---------------------------------------------|
| <code>SUPER_ADMIN</code>  | Platform-wide   | All endpoints, all tenants                  |
| <code>TENANT_ADMIN</code> | Own tenant only | All event, guest, vendor, memory operations |
| <code>EVENT_ADMIN</code>  | Own tenant only | Read events, manage guests and invites      |

## STANDARD RESPONSE FORMAT

---

All responses follow this structure:

```
{
  "status": "ok" | "error",
  "data": { ... },           // present on success
  "message": "..."         // present on error
}
```

# Auth Endpoints

**Base path:** /api/auth

These endpoints manage registration, 2FA, and session tokens.

| Method | Endpoint                  | Description                                      | Auth                 |
|--------|---------------------------|--------------------------------------------------|----------------------|
| POST   | /api/auth/register        | Register a new tenant + admin in one transaction | Firestore token only |
| POST   | /api/auth/request-otp     | Send 6-digit OTP to user email (2FA step 1)      | Firestore token only |
| POST   | /api/auth/verify-otp      | Verify OTP and receive session JWT (2FA step 2)  | Firestore token only |
| POST   | /api/auth/refresh-session | Refresh an expiring session JWT (15min validity) | Firestore + Session  |

## POST /api/auth/register

Creates a Tenant and a TENANT\_ADMIN user in a single atomic transaction. Blocked if the Firestore user already has an account.

**Request Body:**

| Field      | Type   | Required | Description                                     |
|------------|--------|----------|-------------------------------------------------|
| username   | string | Yes      | Display name for the admin user                 |
| tenantName | string | Yes      | Name of the tenant organisation                 |
| tenantSlug | string | Yes      | URL-safe unique identifier (e.g. "levy-events") |

**Success Response — 201 Created:**

```
{ "status": "ok", "data": {
  "user": { "id", "email", "username", "role", "tenantId" },
  "tenant": { "id", "name", "slug", "subscriptionTier" }
}}
```

## POST /api/auth/request-otp

Generates a 6-digit OTP, stores it with a 10-minute expiry, and sends it to the user's registered email via Resend. No request body required. The user is identified by their Firestore token.

**Success Response — 200 OK:**

```
{ "status": "ok", "data": { "message": "Verification code sent to your email." } }
```

## POST /api/auth/verify-otp

Validates the OTP against the stored record, marks it as used, and issues a signed 15-minute session JWT.

#### Request Body:

| Field | Type   | Required | Description                        |
|-------|--------|----------|------------------------------------|
| otp   | string | Yes      | 6-digit code received in the email |

#### Success Response — 200 OK:

```
{ "status": "ok", "data": {  
  "sessionToken": "eyJ...",  
  "expiresIn": "15m",  
  "user": { "id", "email", "username", "role", "tenantId" }  
}}
```

## POST /api/auth/refresh-session

Issues a fresh 15-minute session JWT. Call this when the frontend detects the token is near expiry and the user is still active.

#### Additional Header Required:

```
X-Session-Token: <current_session_jwt>
```

#### Success Response — 200 OK:

```
{ "status": "ok", "data": { "sessionToken": "eyJ...", "expiresIn": "15m" } }
```

# Tenant Endpoints

Base path: `/api/tenants`

SUPER\_ADMIN only. Manages the top-level workspace for each event organiser.

| Method | Endpoint                      | Description                           | Auth               |
|--------|-------------------------------|---------------------------------------|--------------------|
| GET    | <code>/api/tenants</code>     | Get all tenants on the platform       | <i>SUPER_ADMIN</i> |
| GET    | <code>/api/tenants/:id</code> | Get a single tenant by ID             | <i>SUPER_ADMIN</i> |
| POST   | <code>/api/tenants</code>     | Create a tenant manually              | <i>SUPER_ADMIN</i> |
| PUT    | <code>/api/tenants/:id</code> | Update tenant details or subscription | <i>SUPER_ADMIN</i> |
| DELETE | <code>/api/tenants/:id</code> | Archive a tenant (soft delete)        | <i>SUPER_ADMIN</i> |

## POST `/api/tenants` — Request Body

| Field                         | Type                              | Required | Description                      |
|-------------------------------|-----------------------------------|----------|----------------------------------|
| <code>name</code>             | <code>string</code>               | Yes      | Tenant organisation name         |
| <code>slug</code>             | <code>string</code>               | Yes      | Unique URL-safe identifier       |
| <code>email</code>            | <code>string</code>               | Yes      | Primary contact email for tenant |
| <code>subscriptionTier</code> | SPARK  <br>CELEBRATE<br>  ELEVATE | No       | Defaults to SPARK                |

## PUT `/api/tenants/:id` — Request Body

| Field                           | Type                                 | Required | Description                |
|---------------------------------|--------------------------------------|----------|----------------------------|
| <code>name</code>               | <code>string</code>                  | No       | Updated organisation name  |
| <code>email</code>              | <code>string</code>                  | No       | Updated contact email      |
| <code>subscriptionTier</code>   | SPARK  <br>CELEBRATE<br>  ELEVATE    | No       | Change subscription tier   |
| <code>subscriptionStatus</code> | ACTIVE  <br>SUSPENDED<br>  CANCELLED | No       | Change subscription status |

# User Endpoints

---

**Base path:** `/api/users`

TENANT\_ADMIN and above. Manages platform users within a tenant.

| Method | Endpoint                    | Description                                        | Auth          |
|--------|-----------------------------|----------------------------------------------------|---------------|
| GET    | <code>/api/users</code>     | Get all users (scoped to requesting user's tenant) | TENANT_ADMIN+ |
| GET    | <code>/api/users/:id</code> | Get a single user by ID                            | TENANT_ADMIN+ |
| POST   | <code>/api/users</code>     | Create a new user under a tenant                   | TENANT_ADMIN+ |
| PUT    | <code>/api/users/:id</code> | Update user details or role                        | TENANT_ADMIN+ |
| DELETE | <code>/api/users/:id</code> | Archive a user (soft delete)                       | TENANT_ADMIN+ |

## POST `/api/users` — Request Body

| Field                    | Type                             | Required | Description                                        |
|--------------------------|----------------------------------|----------|----------------------------------------------------|
| <code>firebaseUid</code> | string                           | Yes      | The user's Firebase UID — create in Firebase first |
| <code>email</code>       | string                           | Yes      | User email address                                 |
| <code>username</code>    | string                           | Yes      | Display name                                       |
| <code>role</code>        | TENANT_ADMIN<br> <br>EVENT_ADMIN | Yes      | Role within the tenant                             |
| <code>tenantId</code>    | string                           | No       | Defaults to the requesting user's tenant           |

# Event Endpoints

Base path: `/api/events`

EVENT\_ADMIN and above. All events are scoped to the requesting user's tenant.

| Method | Endpoint                     | Description                                     | Auth         |
|--------|------------------------------|-------------------------------------------------|--------------|
| GET    | <code>/api/events</code>     | Get all events for the tenant                   | EVENT_ADMIN+ |
| GET    | <code>/api/events/:id</code> | Get a single event with its days and memory hub | EVENT_ADMIN+ |
| POST   | <code>/api/events</code>     | Create a new event                              | EVENT_ADMIN+ |
| PUT    | <code>/api/events/:id</code> | Update event details or status                  | EVENT_ADMIN+ |
| DELETE | <code>/api/events/:id</code> | Archive an event (soft delete)                  | EVENT_ADMIN+ |

## POST `/api/events` — Request Body

| Field                      | Type   | Required | Description                          |
|----------------------------|--------|----------|--------------------------------------|
| <code>name</code>          | string | Yes      | Event name                           |
| <code>description</code>   | string | No       | Event description                    |
| <code>location</code>      | string | Yes      | Venue name                           |
| <code>address</code>       | string | No       | Full street address                  |
| <code>latitude</code>      | number | No       | Used for vendor proximity matching   |
| <code>longitude</code>     | number | No       | Used for vendor proximity matching   |
| <code>coverImageUrl</code> | string | No       | Cloudinary URL for event cover image |

## PUT `/api/events/:id` — Request Body

| Field                      | Type                                                  | Required | Description             |
|----------------------------|-------------------------------------------------------|----------|-------------------------|
| <code>name</code>          | string                                                | No       | Updated event name      |
| <code>description</code>   | string                                                | No       | Updated description     |
| <code>location</code>      | string                                                | No       | Updated venue name      |
| <code>address</code>       | string                                                | No       | Updated address         |
| <code>latitude</code>      | number                                                | No       | Updated coordinates     |
| <code>longitude</code>     | number                                                | No       | Updated coordinates     |
| <code>coverImageUrl</code> | string                                                | No       | Updated cover image URL |
| <code>status</code>        | DRAFT  <br>PUBLISHED  <br>COMPLETED<br> <br>CANCELLED | No       | Updated event status    |

# Event Day Endpoints

---

**Base path:** `/api/events/:eventId/days`

EVENT\_ADMIN and above. Event days define the individual days of a multi-day event. Invites reference specific days.

| Method | Endpoint                                   | Description                 | Auth         |
|--------|--------------------------------------------|-----------------------------|--------------|
| GET    | <code>/api/events/:eventId/days</code>     | Get all days for an event   | EVENT_ADMIN+ |
| GET    | <code>/api/events/:eventId/days/:id</code> | Get a single event day      | EVENT_ADMIN+ |
| POST   | <code>/api/events/:eventId/days</code>     | Add a day to an event       | EVENT_ADMIN+ |
| PUT    | <code>/api/events/:eventId/days/:id</code> | Update a day's details      | EVENT_ADMIN+ |
| DELETE | <code>/api/events/:eventId/days/:id</code> | Archive a day (soft delete) | EVENT_ADMIN+ |

## POST `/api/events/:eventId/days` — Request Body

| Field                  | Type                  | Required | Description                                  |
|------------------------|-----------------------|----------|----------------------------------------------|
| <code>label</code>     | string                | Yes      | Human-readable label e.g. "Day 1 – Ceremony" |
| <code>date</code>      | string (ISO date)     | Yes      | Date of this day e.g. "2025-08-01"           |
| <code>startTime</code> | string (ISO datetime) | No       | Start time e.g. "2025-08-01T18:00:00.000Z"   |
| <code>endTime</code>   | string (ISO datetime) | No       | End time e.g. "2025-08-01T23:00:00.000Z"     |



# Guest Endpoints

---

Base path: `/api/guests`

EVENT\_ADMIN and above. Guests are not platform users. They interact only through invite links.

| Method | Endpoint                     | Description                   | Auth         |
|--------|------------------------------|-------------------------------|--------------|
| GET    | <code>/api/guests</code>     | Get all guests                | EVENT_ADMIN+ |
| GET    | <code>/api/guests/:id</code> | Get a single guest            | EVENT_ADMIN+ |
| POST   | <code>/api/guests</code>     | Create a guest record         | EVENT_ADMIN+ |
| PUT    | <code>/api/guests/:id</code> | Update guest details          | EVENT_ADMIN+ |
| DELETE | <code>/api/guests/:id</code> | Archive a guest (soft delete) | EVENT_ADMIN+ |

## POST `/api/guests` — Request Body

| Field                    | Type   | Required | Description                                  |
|--------------------------|--------|----------|----------------------------------------------|
| <code>firstName</code>   | string | Yes      | Guest first name                             |
| <code>surname</code>     | string | Yes      | Guest surname                                |
| <code>email</code>       | string | No       | Guest email — used for EMAIL delivery method |
| <code>phoneNumber</code> | string | No       | Guest phone — used for SMS delivery method   |

# Invite Endpoints

**Base path:** `/api/events/:eventId/invites`

EVENT\_ADMIN and above. Creating an invite generates a unique token automatically and links the guest to specific event days.

| Method | Endpoint                                      | Description                                    | Auth         |
|--------|-----------------------------------------------|------------------------------------------------|--------------|
| GET    | <code>/api/events/:eventId/invites</code>     | Get all invites for an event                   | EVENT_ADMIN+ |
| GET    | <code>/api/events/:eventId/invites/:id</code> | Get a single invite with guest and day details | EVENT_ADMIN+ |
| POST   | <code>/api/events/:eventId/invites</code>     | Create an invite for a guest                   | EVENT_ADMIN+ |
| PUT    | <code>/api/events/:eventId/invites/:id</code> | Update invite status or delivery method        | EVENT_ADMIN+ |
| DELETE | <code>/api/events/:eventId/invites/:id</code> | Archive an invite (soft delete)                | EVENT_ADMIN+ |

## POST `/api/events/:eventId/invites` — Request Body

| Field                       | Type                  | Required | Description                                    |
|-----------------------------|-----------------------|----------|------------------------------------------------|
| <code>guestId</code>        | string                | Yes      | ID of the guest to invite                      |
| <code>deliveryMethod</code> | EMAIL   SMS           | Yes      | How the invite link will be sent               |
| <code>invitedDayIds</code>  | string[]              | Yes      | Array of EventDay IDs this guest is invited to |
| <code>expiresAt</code>      | string (ISO datetime) | No       | When the invite token expires                  |

*Note: The invite token is generated automatically and returned in the response. Use this token to construct the RSVP link: `https://eventgenie.com/rsvp?token={token}`*

# Attendance Endpoints

---

**Base path:** /api/attendance

EVENT\_ADMIN and above. Records which event days a guest has confirmed attendance for.

| Method | Endpoint                         | Description                                     | Auth         |
|--------|----------------------------------|-------------------------------------------------|--------------|
| GET    | /api/attendance/invite/:inviteId | Get all attendance records for an invite        | EVENT_ADMIN+ |
| GET    | /api/attendance/:id              | Get a single attendance record                  | EVENT_ADMIN+ |
| POST   | /api/attendance                  | Record attendance for a guest on a specific day | EVENT_ADMIN+ |
| DELETE | /api/attendance/:id              | Remove an attendance record (hard delete)       | EVENT_ADMIN+ |

## POST /api/attendance — Request Body

| Field      | Type   | Required | Description                         |
|------------|--------|----------|-------------------------------------|
| inviteId   | string | Yes      | ID of the invite                    |
| eventDayId | string | Yes      | ID of the event day being confirmed |

# Memory Hub Endpoints

Base path: `/api/events/:eventId/memory-hub`

EVENT\_ADMIN and above. One Memory Hub exists per event. It collects photos and videos from attendees after the event.

| Method | Endpoint                                                      | Description                        | Auth         |
|--------|---------------------------------------------------------------|------------------------------------|--------------|
| GET    | <code>/api/events/:eventId/memory-hub</code>                  | Get the memory hub for an event    | EVENT_ADMIN+ |
| POST   | <code>/api/events/:eventId/memory-hub</code>                  | Create the memory hub for an event | EVENT_ADMIN+ |
| PUT    | <code>/api/events/:eventId/memory-hub/:id</code>              | Update hub title or description    | EVENT_ADMIN+ |
| POST   | <code>/api/events/:eventId/memory-hub/:id/make-public</code>  | Generate a public shareable link   | EVENT_ADMIN+ |
| DELETE | <code>/api/events/:eventId/memory-hub/:id</code>              | Archive the memory hub             | EVENT_ADMIN+ |
| GET    | <code>/api/events/:eventId/memory-hub/:hubId/items</code>     | Get all media items in a hub       | EVENT_ADMIN+ |
| GET    | <code>/api/events/:eventId/memory-hub/:hubId/items/:id</code> | Get a single media item            | EVENT_ADMIN+ |
| POST   | <code>/api/events/:eventId/memory-hub/:hubId/items</code>     | Upload a media item                | EVENT_ADMIN+ |
| PUT    | <code>/api/events/:eventId/memory-hub/:hubId/items/:id</code> | Update caption or approval status  | EVENT_ADMIN+ |
| DELETE | <code>/api/events/:eventId/memory-hub/:hubId/items/:id</code> | Archive a media item               | EVENT_ADMIN+ |

## POST `/api/events/:eventId/memory-hub` — Request Body

| Field                    | Type   | Required | Description                                  |
|--------------------------|--------|----------|----------------------------------------------|
| <code>title</code>       | string | No       | Hub title e.g. "Amapiano Saturdays Memories" |
| <code>description</code> | string | No       | Short description of the memory collection   |

## POST `.../:hubId/items` — Request Body

| Field                          | Type          | Required | Description                          |
|--------------------------------|---------------|----------|--------------------------------------|
| <code>mediaUrl</code>          | string        | Yes      | Cloudinary URL of the uploaded media |
| <code>mediaType</code>         | IMAGE   VIDEO | Yes      | Type of media                        |
| <code>caption</code>           | string        | No       | Optional caption for the item        |
| <code>uploadedByGuestId</code> | string        | No       | Guest ID if uploaded by a guest      |
| <code>uploadedByUserId</code>  | string        | No       | User ID if uploaded by an organiser  |



# Vendor Endpoints

**Base path:** `/api/vendors`

The Vendor Marketplace connects event organizers with nearby service providers.

## VENDOR SPACE

| Method | Endpoint                         | Description                                     | Auth                 |
|--------|----------------------------------|-------------------------------------------------|----------------------|
| GET    | <code>/api/vendors</code>        | Get all vendor spaces (tenant-scoped)           | <i>EVENT_ADMIN+</i>  |
| GET    | <code>/api/vendors/nearby</code> | Find vendors near a location (proximity search) | <i>EVENT_ADMIN+</i>  |
| GET    | <code>/api/vendors/:id</code>    | Get a single vendor space with services         | <i>EVENT_ADMIN+</i>  |
| POST   | <code>/api/vendors</code>        | Create a vendor space                           | <i>TENANT_ADMIN+</i> |
| PUT    | <code>/api/vendors/:id</code>    | Update vendor space details                     | <i>TENANT_ADMIN+</i> |
| DELETE | <code>/api/vendors/:id</code>    | Archive a vendor space                          | <i>TENANT_ADMIN+</i> |

### GET `/api/vendors/nearby` — Query Parameters

| Field                  | Type                | Required | Description                       |
|------------------------|---------------------|----------|-----------------------------------|
| <code>latitude</code>  | <code>number</code> | Yes      | Latitude of the event location    |
| <code>longitude</code> | <code>number</code> | Yes      | Longitude of the event location   |
| <code>radius</code>    | <code>number</code> | No       | Search radius in km (default: 50) |

### POST `/api/vendors` — Request Body

| Field                    | Type                | Required | Description                                               |
|--------------------------|---------------------|----------|-----------------------------------------------------------|
| <code>name</code>        | <code>string</code> | Yes      | Vendor business name                                      |
| <code>description</code> | <code>string</code> | No       | About the vendor                                          |
| <code>email</code>       | <code>string</code> | Yes      | Contact email                                             |
| <code>phoneNumber</code> | <code>string</code> | No       | Contact phone                                             |
| <code>website</code>     | <code>string</code> | No       | Website URL                                               |
| <code>address</code>     | <code>string</code> | No       | Street address                                            |
| <code>latitude</code>    | <code>number</code> | Yes      | Vendor location latitude (required for proximity search)  |
| <code>longitude</code>   | <code>number</code> | Yes      | Vendor location longitude (required for proximity search) |

## VENDOR SERVICES

| Method | Endpoint                                 | Description                   | Auth          |
|--------|------------------------------------------|-------------------------------|---------------|
| GET    | /api/vendors/:vendorSpaceId/services     | Get all services for a vendor | EVENT_ADMIN+  |
| GET    | /api/vendors/:vendorSpaceId/services/:id | Get a single service          | EVENT_ADMIN+  |
| POST   | /api/vendors/:vendorSpaceId/services     | Add a service to a vendor     | TENANT_ADMIN+ |
| PUT    | /api/vendors/:vendorSpaceId/services/:id | Update a service              | TENANT_ADMIN+ |
| DELETE | /api/vendors/:vendorSpaceId/services/:id | Archive a service             | TENANT_ADMIN+ |

## POST /api/vendors/:vendorSpaceId/services — Request Body

| Field          | Type                                                                           | Required | Description                         |
|----------------|--------------------------------------------------------------------------------|----------|-------------------------------------|
| name           | string                                                                         | Yes      | Service name e.g. "Buffet Catering" |
| category       | CATERING   DECOR   FURNITURE   PHOTOGRAPHY   ENTERTAINMENT   FLORISTRY   OTHER | Yes      | Service category                    |
| description    | string                                                                         | No       | Service description                 |
| operatingDays  | string                                                                         | No       | e.g. "Monday to Sunday"             |
| operatingHours | string                                                                         | No       | e.g. "08:00 - 22:00"                |

## PRODUCTS

| Method | Endpoint                                                     | Description                    | Auth          |
|--------|--------------------------------------------------------------|--------------------------------|---------------|
| GET    | /api/vendors/:vendorSpaceId/services/:serviceId/products     | Get all products for a service | EVENT_ADMIN+  |
| GET    | /api/vendors/:vendorSpaceId/services/:serviceId/products/:id | Get a single product           | EVENT_ADMIN+  |
| POST   | /api/vendors/:vendorSpaceId/services/:serviceId/products     | Add a product to a service     | TENANT_ADMIN+ |
| PUT    | /api/vendors/:vendorSpaceId/services/:serviceId/products/:id | Update a product               | TENANT_ADMIN+ |
| DELETE | /api/vendors/:vendorSpaceId/services/:serviceId/products/:id | Archive a product              | TENANT_ADMIN+ |

## POST .../products — Request Body

| Field | Type   | Required | Description  |
|-------|--------|----------|--------------|
| name  | string | Yes      | Product name |

| Field       | Type     | Required | Description                     |
|-------------|----------|----------|---------------------------------|
| description | string   | No       | Product description             |
| price       | number   | No       | Price in the specified currency |
| currency    | string   | No       | Currency code (default: ZAR)    |
| imageUrls   | string[] | No       | Array of Cloudinary image URLs  |



# Subscription Tier Config Endpoints

Base path: `/api/subscription-tiers`

`SUPER_ADMIN` only. Manages the feature limits for each subscription tier.

| Method | Endpoint                                   | Description                                 | Auth                     |
|--------|--------------------------------------------|---------------------------------------------|--------------------------|
| GET    | <code>/api/subscription-tiers</code>       | Get all tier configurations                 | <code>SUPER_ADMIN</code> |
| GET    | <code>/api/subscription-tiers/:tier</code> | Get config for SPARK, CELEBRATE, or ELEVATE | <code>SUPER_ADMIN</code> |
| POST   | <code>/api/subscription-tiers</code>       | Create a tier config (initial setup)        | <code>SUPER_ADMIN</code> |
| PUT    | <code>/api/subscription-tiers/:tier</code> | Update limits or feature flags for a tier   | <code>SUPER_ADMIN</code> |

## POST `/api/subscription-tiers` — Request Body

| Field                          | Type                                     | Required | Description                                      |
|--------------------------------|------------------------------------------|----------|--------------------------------------------------|
| <code>tier</code>              | <code>SPARK   CELEBRATE   ELEVATE</code> | Yes      | The tier being configured                        |
| <code>maxEvents</code>         | <code>number   null</code>               | No       | Max active events (null = unlimited)             |
| <code>maxGuestsPerEvent</code> | <code>number   null</code>               | No       | Max guests per event (null = unlimited)          |
| <code>maxSmsPerMonth</code>    | <code>number   null</code>               | No       | Max SMS per billing period (null = unlimited)    |
| <code>emailEnabled</code>      | <code>boolean</code>                     | Yes      | Whether email invitations are enabled            |
| <code>smsEnabled</code>        | <code>boolean</code>                     | Yes      | Whether SMS invitations are enabled              |
| <code>vendorMarketplace</code> | <code>boolean</code>                     | Yes      | Whether vendor marketplace is accessible         |
| <code>memoryHubEnabled</code>  | <code>boolean</code>                     | Yes      | Whether Memory Hub is accessible                 |
| <code>dragDropBuilder</code>   | <code>boolean</code>                     | Yes      | Whether drag-and-drop RSVP builder is accessible |

# Error Reference

---

| HTTP Status | Meaning      | Common Causes                                                                            |
|-------------|--------------|------------------------------------------------------------------------------------------|
| 400         | Bad Request  | Missing required fields, invalid body format                                             |
| 401         | Unauthorized | Missing Authorization header, invalid Firebase token, missing or expired X-Session-Token |
| 403         | Forbidden    | Valid token but insufficient role for this endpoint                                      |
| 404         | Not Found    | Route does not exist                                                                     |
| 500         | Server Error | Unexpected error — check server logs                                                     |